

DOCUMENTATION TECHNIQUE

Infrastructure SSO / Double Authentification (MFA)

Authelia • Nginx • Docker-Mailserver • Active Directory

Domaine : cyna.labo | Date : 14 mai 2026 | Version : 1.0

Résumé exécutif

Ce document décrit la mise en place complète d'une infrastructure d'authentification forte (SSO + MFA) pour le domaine cyna.labo. La solution repose sur Authelia (portail d'authentification), un serveur mail interne (Docker-Mailserver), un reverse proxy Nginx avec SSL/TLS, et un annuaire Active Directory. L'accès au SIEM Wazuh est désormais protégé par une double authentification obligatoire.

1. Architecture Générale

L'infrastructure mise en place repose sur une segmentation réseau stricte avec une DMZ hébergeant le reverse proxy Nginx, un réseau serveur contenant les services internes (Authelia, AD, Wazuh), et un réseau Docker isolé pour les conteneurs.

1.1 Inventaire des composants

Composant	IP / Réseau	Rôle	Ports exposés
Nginx (Reverse Proxy)	10.0.20.2 (DMZ)	Point d'entrée HTTPS	80, 443, 993, 143
Authelia	10.0.40.5	SSO + MFA	9091 (interne)
Mailserver	172.20.0.10 (Docker)	SMTP / IMAP	25, 587, 143, 993
Active Directory	10.0.40.2	DNS + LDAP	389, 636, 53
Wazuh	10.0.40.3	SIEM	443

1.2 Flux d'authentification

Le flux de double authentification fonctionne selon les étapes suivantes :

- L'utilisateur accède à <https://wazuh.cyna.labo> depuis son navigateur
- Nginx intercepte la requête et envoie une subrequest à Authelia (/api/verify)
- Authelia retourne 401 → Nginx redirige vers <https://authelia.cyna.labo>
- L'utilisateur saisit ses identifiants AD (1er facteur — LDAP)
- Authelia envoie un One-Time Code par email (2ème facteur)
- L'utilisateur saisit le code reçu → accès accordé à Wazuh

Schéma simplifié

Navigateur → [HTTPS] → Nginx (10.0.20.2)
Nginx → [subrequest] → Authelia (10.0.40.5:9091)
Authelia → [LDAP] → Active Directory (10.0.40.2)
Authelia → [SMTP] → Mailserver (172.20.0.10) → Email utilisateur
Nginx → [proxy_pass] → Wazuh (10.0.40.3:443)

2. Installation et Configuration

2.1 Structure des fichiers

Tous les fichiers de configuration sont centralisés dans `/opt/authelia/` sur le serveur Authelia :

```
/opt/authelia/  
├─ docker-compose.yml      # Orchestration Docker  
├─ configuration.yml       # Configuration Authelia  
├─ db.sqlite3             # Base de données Authelia  
├─ mail-data/             # Boîtes mail (Dovecot)  
├─ mail-state/            # État Postfix  
└─ mail-config/           # Config mailserver (postfix, dovecot)
```

2.2 Docker Compose

Le fichier `docker-compose.yml` définit deux services : Authelia et le serveur mail.

```
services:  
  authelia:  
    image: authelia/authelia:latest  
    volumes:  
      - /opt/authelia:/config  
    networks:  
      - authelia_net  
    ports:  
      - '9091:9091'  
  
  mailserver:  
    image: ghcr.io/docker-mailserver/docker-mailserver:latest  
    environment:  
      - PERMIT_DOCKER=connected  
      - ENABLE_AMAVIS=0  
      - ENABLE_SPAMASSASSIN=0  
      - ENABLE_CLAMAV=0  
    networks:  
      authelia_net:  
        ipv4_address: 172.20.0.10
```

2.3 Configuration Authelia

Configuration complète du fichier `/opt/authelia/configuration.yml` :

```
authentication_backend:  
  ldap:  
    implementation: activedirectory  
    address: ldap://10.0.40.2  
    base_dn: dc=cyna,dc=labo
```

```
users_filter: >-
  (&|(({username_attribute}={input}))
    (mail={input})) (objectCategory=person)
    (objectClass=user))
user: administrateur@cyna.labo

session:
  cookies:
    - domain: 'cyna.labo'
      authelia_url: 'https://authelia.cyna.labo'

notifier:
  smtp:
    address: smtp://mailserver:25
    disable_require_tls: true
```

2.4 Configuration Nginx

Le fichier `/etc/nginx/sites-available/wazuh` configure le reverse proxy et la protection par Authelia :

```
# Bloc Authelia (portail de connexion)
server {
    listen 443 ssl;
    server_name authelia.cyna.labo;
    ssl_certificate /etc/ssl/cyna/authelia.crt;
    location / {
        proxy_pass http://10.0.40.5:9091;
    }
}

# Bloc Wazuh (protégé par Authelia)
server {
    listen 443 ssl;
    server_name wazuh.cyna.labo;
    location / {
        auth_request /authelia;
        error_page 401 403 =302 https://authelia.cyna.labo/...;
        proxy_pass https://10.0.40.3:443;
    }
    location = /authelia {
        internal;
        proxy_pass http://10.0.40.5:9091/api/verify;
    }
}
```

2.5 PKI interne — Certificats SSL

Une autorité de certification (CA) interne a été créée sur le serveur Nginx pour générer les certificats SSL des services.

```
# Création de la CA
openssl genrsa -out ca.key 4096
openssl req -new -x509 -days 3650 -key ca.key -out ca.crt \
  -subj '/C=FR/ST=France/O=Cyna/CN=Cyna-CA'

# Certificat pour authelia.cyna.labo
openssl genrsa -out authelia.key 2048
openssl req -new -key authelia.key -out authelia.csr
openssl x509 -req -days 825 -in authelia.csr -CA ca.crt \
  -CAkey ca.key -out authelia.crt
```

Important — Distribution du certificat CA

Le certificat ca.crt doit être installé sur toutes les machines clientes pour éviter les avertissements SSL. Sur Debian/Ubuntu : update-ca-certificates
Sur Windows : importer dans 'Autorités de certification racines de confiance'

3. Configuration DNS

Les enregistrements DNS suivants ont été créés sur l'Active Directory (10.0.40.2) pour pointer vers le reverse proxy Nginx :

Nom d'hôte	Type	Valeur	Remarque
authelia	A	10.0.20.2	Portail d'authentification
wazuh	A	10.0.20.2	SIEM protégé par MFA
mail	A	10.0.40.5	Serveur mail interne

Note : Les machines clientes doivent utiliser l'AD (10.0.40.2) comme serveur DNS primaire pour résoudre correctement ces noms.

4. Problèmes Rencontrés et Solutions

Cette section documente l'ensemble des incidents techniques rencontrés lors du déploiement, leurs causes identifiées et les solutions appliquées.

4.1 Tableau récapitulatif des incidents

Problème	Cause	Solution
LDAP — connection reset	Authelia tentait ldaps:// vers une ancienne IP (10.0.40.2:636) non configurée	Correction de l'adresse LDAP vers ldap://10.0.40.2 avec skip_verify: true
SMTP — connection refused	Le mailserver n'était pas démarré ou Postfix n'avait pas les bonnes permissions	chown -R 999:999 sur mail-state et mail-data, puis restart
SMTP — STARTTLS obligatoire	Authelia exigeait STARTTLS mais le mailserver n'était pas configuré	Ajout de disable_require_tls: true dans la config Authelia
Clé de chiffrement invalide	La clé encryption_key ne correspondait plus à la base SQLite existante	Suppression de db.sqlite3 et recréation automatique
users_filter invalide	Le placeholder {username_attribute} était supprimé par le heredoc bash	Edition directe avec nano pour préserver les accolades
Postfix — Permission denied	Les volumes Docker créaient les dossiers avec UID root au lieu de 999	chown -R 999:999 après chaque redémarrage du mailserver
Postfix — Client rejected	La restriction PERMIT_DOCKER=network n'autorisait pas le réseau Authelia	postconf -e 'smtpd_client_restrictions = permit_mynetworks, reject'
Postfix — Timeout MAIL FROM	Le paramètre dms_smtpd_sender_restrictions était indéfini	postconf -e 'smtpd_sender_restrictions = permit_mynetworks, ...'
Postscreen bloquait port 25	Postscreen filtrait les connexions sans whitelist interne	Remplacement de postscreen par smtpd direct sur le port 25
Auth request status 400	Header X-Forwarded-Host manquant dans la subrequest Nginx	Ajout de proxy_set_header X-Forwarded-Host dans le bloc /authelia
Auth request status 302	Nginx ne gère pas les 302 dans auth_request (module limitation)	Changement de l'endpoint vers /api/verify au lieu de /api/authz/forward-auth
Rate limit Authelia	Trop de tentatives de connexion échouées bloquaient l'IP	Attente du délai de cooldown puis redémarrage d'Authelia
Dovecot SSL désactivé	ssl = no dans 10-ssl.conf empêchait le port 993	Modification de 10-ssl.conf et génération d'un certificat auto-signé
DNS incorrect côté client	La machine utilisait 8.8.8.8 ou un DNS ne connaissant pas cyna.labo	Changement du DNS vers 10.0.40.2 (AD) sur les serveurs et clients

4.2 Problèmes récurrents — Permissions Postfix

Problème critique récurrent

À chaque redémarrage du mailserver, Postfix et Amavis perdent leurs permissions sur les dossiers montés (mail-state, mail-data). Cela provoque des erreurs 'Permission denied' et empêche l'envoi de mails.

Solution systématique à appliquer après chaque redémarrage :

```
chown -R 999:999 /opt/authelia/mail-state  
chown -R 999:999 /opt/authelia/mail-data
```

Cause racine : Docker crée les dossiers manquants avec l'UID root (0) lors du démarrage. docker-mailserver utilise l'UID 999 en interne. Une solution pérenne serait de pré-créeer les dossiers avec les bonnes permissions avant le premier démarrage.

5. Sécurité et Bonnes Pratiques

5.1 Points de sécurité implémentés

- HTTPS obligatoire sur tous les services exposés (Nginx → SSL/TLS)
- PKI interne avec CA propriétaire Cyna pour les certificats
- Double authentification (MFA) pour l'accès à Wazuh
- Redirection HTTP → HTTPS automatique (code 301)
- Authentification LDAP via Active Directory (pas de comptes locaux)
- Réseau Docker isolé (172.20.0.0/24) pour les conteneurs
- Politique de contrôle d'accès par domaine dans Authelia

5.2 Points d'amélioration recommandés

Recommandations pour la production

1. Utiliser ldaps:// (port 636) avec un certificat valide pour sécuriser les échanges LDAP
2. Configurer un compte LDAP dédié (service account) au lieu d'Administrateur
3. Activer STARTTLS ou SSL sur le serveur SMTP (port 587 avec authentification)
4. Mettre en place un script de démarrage automatisant le chown sur mail-state/mail-data
5. Configurer un client TOTP (Google Authenticator) en plus de l'OTP email
6. Sauvegarder régulièrement /opt/authelia (db.sqlite3, configuration.yml)
7. Mettre en place un monitoring des logs Authelia et Nginx

5.3 Politique de contrôle d'accès Authelia

La configuration access_control définit les règles d'accès par domaine :

```
access_control:
  default_policy: one_factor
  rules:
    - domain: 'authelia.cyna.labo'
      policy: bypass      # Portail accessible sans auth
    - domain: 'wazuh.cyna.labo'
      policy: two_factor  # MFA obligatoire
```

6. Procédures de Maintenance

6.1 Démarrage de l'infrastructure

Procédure complète pour démarrer l'infrastructure après un arrêt :

```
# 1. Démarrer les conteneurs
cd /opt/authelia
docker compose up -d

# 2. Corriger les permissions (OBLIGATOIRE)
sleep 15
chown -R 999:999 /opt/authelia/mail-state
chown -R 999:999 /opt/authelia/mail-data
chown -R 999:999 /opt/authelia/mail-config

# 3. Redémarrer le mailserver avec bonnes permissions
docker restart mailserver

# 4. Vérifier que tout fonctionne
docker compose ps
nc -zv 172.20.0.10 587
```

6.2 Vérification de l'état des services

```
# Statut des conteneurs
docker compose ps

# Logs Authelia (dernières 50 lignes)
docker compose logs authelia --tail 50

# Logs mailserver
docker logs mailserver --tail 30

# Test SMTP
nc -zv 172.20.0.10 587

# Test Nginx
nginx -t && systemctl status nginx
```

6.3 Récupération du code OTP par ligne de commande

Si l'accès mail n'est pas disponible, le code OTP peut être récupéré directement depuis le serveur :

```
# Lister les nouveaux mails
ls /opt/authelia/mail-data/cyna.labo/[USER]/new/

# Extraire le code OTP du dernier mail
```

```
ls -t /opt/authelia/mail-data/cyna.labo/[USER]/new/ | \
head -1 | xargs -I{} grep -o '[A-Z0-9]{8}' \
/opt/authelia/mail-data/cyna.labo/[USER]/new/{} 
```

7. Gestion des Comptes Mail et Code OTP

Cette section explique comment créer un compte mail pour un utilisateur et comment récupérer le code OTP envoyé par Authelia lors de l'enregistrement du second facteur.

7.1 Créer un compte mail

Chaque utilisateur qui doit s'authentifier via Authelia doit avoir un compte mail sur le mailserver.

```
# Créer un compte mail
docker exec mailserver setup email add laurent.legue@cyna.labo Azerty123!

# Lister les comptes existants
docker exec mailserver setup email list

# Supprimer un compte
docker exec mailserver setup email del laurent.legue@cyna.labo
```

Important - Adresse mail dans l'Active Directory

L'adresse mail doit également être renseignée dans l'AD.

Sur le serveur AD (PowerShell) :

```
Set-ADUser -Identity 'laurent.legue'
-EmailAddress 'laurent.legue@cyna.labo'
```

Vérification LDAP depuis le serveur Authelia :

```
ldapsearch -H ldap://10.0.40.2 -D 'administrateur@cyna.labo'
-w 'Azerty123!' -b 'dc=cyna,dc=labo'
'(sAMAccountName=laurent.legue)' mail sAMAccountName
```

7.2 Flux d'enregistrement du second facteur

Lors de la première connexion à un service protégé par `two_factor`, Authelia demande d'enregistrer un second facteur :

- L'utilisateur se connecte avec ses identifiants AD (1er facteur)
- Authelia redirige vers la page des réglages 2FA
- L'utilisateur clique AJOUTER sous Mot de passe à usage unique
- Authelia envoie un One-Time Code par email pour vérifier l'identité
- L'utilisateur saisit le code reçu dans le navigateur
- Authelia affiche le QR code TOTP à scanner
- L'utilisateur scanne avec Google Authenticator ou Authy
- Second facteur enregistré - connexions futures : identifiants + code TOTP

7.3 Récupérer le code OTP par ligne de commande

Si l'accès à la boîte mail n'est pas disponible, le code OTP peut être récupéré directement depuis le serveur Authelia en lisant les fichiers mail sur le disque.

Etape 1 - Lister les nouveaux mails

```
# Remplacer USER par le sAMAccountName
ls /opt/authelia/mail-data/cyna.labo/USER/new/

# Exemple
ls /opt/authelia/mail-data/cyna.labo/laurent.legue/new/
```

Etape 2 - Extraire le code OTP

Le code OTP est un code alphanumérique de 8 caractères en majuscules. Il apparaît deux fois dans le mail (texte brut + HTML).

```
ls -t /opt/authelia/mail-data/cyna.labo/USER/new/ | \
  head -1 | \
  xargs -I{} grep -o '[A-Z0-9]\{8\}' \
  /opt/authelia/mail-data/cyna.labo/USER/new/{}

OU

MAIL_DIR="/opt/authelia/mail-data/cyna.labo/laurent.legue/new"
grep -o '[A-Z0-9]\{8\}' "$MAIL_DIR/$(ls -t "$MAIL_DIR" | head -n 1)"
```

Exemple de sortie - le code qui apparaît deux fois est le bon :

```
EAAAZU03
GENERATE
UBHE8Z6Y    <-- Code OTP (apparaît 2 fois)
UBHE8Z6Y
```

Attention - Expiration du code OTP

Le code OTP a une durée de vie limitée (quelques minutes).
Si expire : cliquer ANNULER puis AJOUTER pour un nouveau code.
En cas de Rate Limit : attendre 5 minutes ou redémarrer Authelia.
docker compose restart authelia

7.4 Script de récupération automatique

Script bash à créer sur le serveur Authelia pour simplifier la récupération du code OTP :

```
nano /opt/authelia/get_otp.sh

#!/bin/bash
# Usage: ./get_otp.sh <username>
```

```
USER=$1
MAIL_DIR=/opt/authelia/mail-data/cyna.labo/$USER/new
if [ -z "$USER" ]; then echo 'Usage: $0 <username>'; exit 1; fi
LAST=$(ls -t $MAIL_DIR 2>/dev/null | head -1)
if [ -z "$LAST" ]; then echo 'Aucun mail trouve'; exit 1; fi
echo "Code OTP : "
grep -o '[A-Z0-9]\{8\}' "$MAIL_DIR/$LAST" | sort | uniq -d
```

```
chmod +x /opt/authelia/get_otp.sh
./get_otp.sh laurent.legue
```

8. References et Versions

Composant	Version	Source
Authelia	v4.39.19	authelia/authelia:latest
Docker-Mailserver	latest	ghcr.io/docker-mailserver/docker-mailserver
Nginx	1.26.3	Debian Trixie
Docker	latest	docker.io
Active Directory	Windows Server 2022	Domain Level 7

Document rédigé le 14 mai 2026 — Infrastructure Cyna.labo